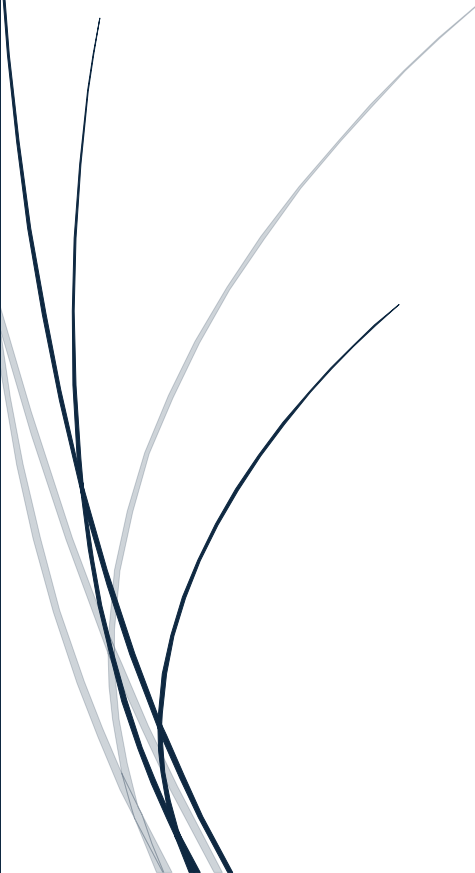




10/5/2025

Homework 3:

IAM Enumeration



Levine, Miles L

MLEVIN56 ENPM665 0101

Contents

1) AWS CLI Configuration & Setup.....	2
2) IAM User & Role Enumeration	2
3) Policy Analysis & Access Implications	3
4) Identifying Accessible Resources (Data Exposure)	5
5) Security Misconfigurations & Risks	6
6) Flag Discovery & Documentation.....	6
7) Mitigation Strategies.....	6
8) Conclusion	7

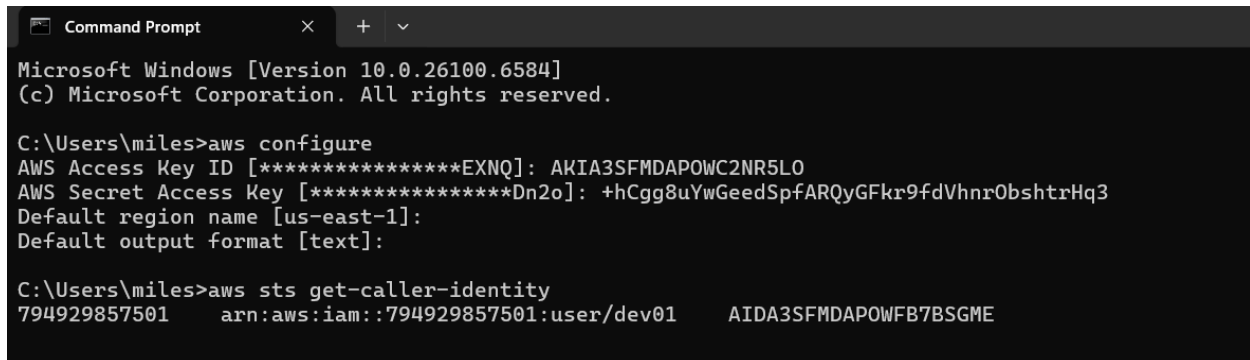
1. AWS CLI Configuration & Setup

I have already installed AWS CLI on my windows machine. After beginning the lab, I configured a dedicated AWS CLI profile using the lab-supplied access key, secret key, and region. Identity was verified via STS.

Commands executed:

aws configure

aws sts get-caller-identity



```
Microsoft Windows [Version 10.0.26100.6584]
(c) Microsoft Corporation. All rights reserved.

C:\Users\miles>aws configure
AWS Access Key ID [*****EXNQ]: AKIA3SFMDAPOWC2NR5LO
AWS Secret Access Key [*****Dn2o]: +hCgg8uYwGeedSpfARQyGFkr9fdVhnr0bshtHq3
Default region name [us-east-1]:
Default output format [text]:

C:\Users\miles>aws sts get-caller-identity
794929857501    arn:aws:iam::794929857501:user/dev01    AIDA3SFMDAPOWFB7BSGME
```

Figure 1 STS identity for dev01.

2. IAM User & Role Enumeration

I queried IAM for the user, policy attachments, inline policies, and roles. No groups were returned.

Observed principals and memberships:

User: dev01

Groups: none

Attached user policies: AmazonGuardDutyReadOnlyAccess, policy/dev01

Inline user policies: cloudshell, S3_Access

Roles discovered: BackendDev

Commands executed:

aws iam get-user

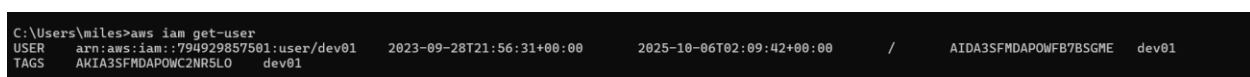
aws iam list-groups-for-user --user-name dev01

aws iam list-attached-user-policies --user-name dev01

aws iam list-user-policies --user-name dev01

aws iam get-role --role-name BackendDev

aws iam list-attached-role-policies --role-name BackendDev



```
C:\Users\miles>aws iam get-user
USER      arn:aws:iam::794929857501:user/dev01    2023-09-28T21:56:31+00:00    2025-10-06T02:09:42+00:00    /    AIDA3SFMDAPOWFB7BSGME    dev01
TAGS      AKIA3SFMDAPOWC2NR5LO    dev01
```

Figure 2 IAM get-user for dev01

```
C:\Users\miles>aws iam list-groups-for-user --user-name dev01
```

Figure 3 No groups for dev01

```
C:\Users\miles>aws iam list-attached-user-policies --user-name dev01
ATTACHEDPOLICIES    arn:aws:iam::aws:policy/AmazonGuardDutyReadOnlyAccess    AmazonGuardDutyReadOnlyAccess
ATTACHEDPOLICIES    arn:aws:iam::794929857501:policy/dev01    dev01
```

Figure 4 Attached user policies for dev01

```
C:\Users\miles>aws iam list-user-policies --user-name dev01
POLICYNAMES    cloudshell
POLICYNAMES    S3_Access
```

Figure 5 Inline policy names for dev01

```
C:\Users\miles>aws iam list-attached-role-policies --role-name BackendDev
ATTACHEDPOLICIES    arn:aws:iam::794929857501:policy/BackendDevPolicy    BackendDevPolicy
```

Figure 6 BackendDev has BackendDevPolicy attached

```
C:\Users\miles>aws iam get-role --role-name BackendDev
ROLE    arn:aws:iam::794929857501:role/BackendDev    2023-09-29T12:30:29+00:00    Grant permissions to backend developers 3600    /
AROA3SFMDAPO2RZ36QVN6    BackendDev
ASSUMEROLEPOLICYDOCUMENT    2012-10-17
STATEMENT    sts:AssumeRole    Allow
PRINCIPAL    arn:aws:iam::794929857501:user/dev01
ROLELASTUSED    2025-10-05T18:06:39+00:00    us-east-1
```

Figure 7 BackendDev trust allows dev01 to assume the role

3. Policy Analysis & Access Implications

I reviewed four policies. I list the allowed actions and the impact.

AmazonGuardDutyReadOnlyAccess v4

Allowed actions. guardduty:Describe*. guardduty:Get*. guardduty:List*.

Impact. Read only visibility into GuardDuty.

dev01 v7

Allowed actions. iam:GetRole. iam:GetPolicyVersion. iam:GetPolicy. iam:ListPolicyVersions. iam:GetUserPolicy. iam:ListGroupsForUser. iam:ListAttachedUserPolicies.

iam:ListUserPolicies. iam:GetUser. iam:ListAttachedRolePolicies. iam:GetRolePolicy.

Resources. arn:aws:iam::794929857501:user/dev01.

arn:aws:iam::794929857501:role/BackendDev.

arn:aws:iam::794929857501:policy/BackendDevPolicy.

arn:aws:iam::794929857501:policy/dev01.

arn:aws:iam::aws:policy/AmazonGuardDutyReadOnlyAccess.

Impact. Broad identity and policy discovery.

BackendDevPolicy v1

Allowed actions. ec2:DescribeInstances. secretsmanager:ListSecrets.

secretsmanager:GetSecretValue on arn:aws:secretsmanager:us-east-

1:794929857501:secret:prod/Customers-QUhpZf. secretsmanager:DescribeSecret.

Impact. If I assume BackendDev, I could read the secret value, subject to KMS or resource policy limits.

S3_Access inline on dev01

Allowed actions. s3:ListBucket. s3:GetObject.

Resources. arn:aws:s3:::hl-dev-artifacts. arn:aws:s3:::hl-dev-artifacts/*.

Impact. Direct object reads from hl-dev-artifacts.

Commands executed

```
aws iam list-policy-versions --policy-arn
```

```
arn:aws:iam::aws:policy/AmazonGuardDutyReadOnlyAccess
```

```
aws iam get-policy-version --policy-arn
```

```
arn:aws:iam::aws:policy/AmazonGuardDutyReadOnlyAccess --version-id v4
```

```
aws iam list-policy-versions --policy-arn arn:aws:iam::794929857501:policy/dev01
```

```
aws iam get-policy-version --policy-arn arn:aws:iam::794929857501:policy/dev01 --version-id v7
```

```
aws iam get-policy --policy-arn arn:aws:iam::794929857501:policy/BackendDevPolicy
```

```
aws iam get-policy-version --policy-arn arn:aws:iam::794929857501:policy/BackendDevPolicy --version-id v1
```

```
aws iam get-user-policy --user-name dev01 --policy-name S3_Access
```

```
C:\Users\miles>aws iam list-policy-versions --policy-arn arn:aws:iam::aws:policy/AmazonGuardDutyReadOnlyAccess
VERSIONS      2023-11-16T23:07:06+00:00    True    v4
VERSIONS      2021-02-16T23:37:57+00:00    False   v3
VERSIONS      2018-04-25T21:07:17+00:00    False   v2
VERSIONS      2017-11-28T22:29:40+00:00    False   v1
```

Figure 8 GuardDuty managed policy version history

```
C:\Users\miles>aws iam get-policy-version --policy-arn arn:aws:iam::aws:policy/AmazonGuardDutyReadOnlyAccess --version-id v4
POLICYVERSION 2023-11-16T23:07:06+00:00    True    v4
DOCUMENT      2012-10-17
STATEMENT     Allow *
ACTION        guardduty:Describe*
ACTION        guardduty:Get*
ACTION        guardduty:List*
STATEMENT     Allow *
ACTION        organizations:ListDelegatedAdministrators
ACTION        organizations:ListAWSServiceAccessForOrganization
ACTION        organizations:DescribeOrganizationalUnit
ACTION        organizations:DescribeAccount
ACTION        organizations:DescribeOrganization
ACTION        organizations:ListAccounts
```

Figure 9 GuardDuty v4 allowed actions

```
C:\Users\miles>aws iam list-policy-versions --policy-arn arn:aws:iam::794929857501:policy/dev01
VERSIONS      2023-10-11T19:59:08+00:00      True    v7
VERSIONS      2023-10-11T19:47:41+00:00      False   v6
VERSIONS      2023-10-07T22:48:28+00:00      False   v5
VERSIONS      2023-10-02T20:38:35+00:00      False   v4
VERSIONS      2023-10-02T20:29:52+00:00      False   v3
```

Figure 10 dev01 policy version history

```
C:\Users\miles>aws iam get-policy-version --policy-arn arn:aws:iam::794929857501:policy/dev01 --version-id v7
POLICYVERSION 2023-10-11T19:59:08+00:00      True    v7
DOCUMENT      2012-10-17
STATEMENT     Allow    VisualEditor0
ACTION        iam:GetRole
ACTION        iam:GetPolicyVersion
ACTION        iam:GetPolicy
ACTION        iam:ListPolicyVersions
ACTION        iam:GetUserPolicy
ACTION        iam:ListGroupsForUser
ACTION        iam:ListAttachedUserPolicies
ACTION        iam:ListUserPolicies
ACTION        iam:GetUser
ACTION        iam:ListAttachedRolePolicies
ACTION        iam:GetRolePolicy
RESOURCE      arn:aws:iam::794929857501:user/dev01
RESOURCE      arn:aws:iam::794929857501:role/BackendDev
RESOURCE      arn:aws:iam::794929857501:policy/BackendDevPolicy
RESOURCE      arn:aws:iam::794929857501:policy/dev01
RESOURCE      arn:aws:iam::aws:policy/AmazonGuardDutyReadOnlyAccess
```

Figure 11 dev01 v7 discovery actions and targeted resources

```
C:\Users\miles>aws iam get-policy-version --policy-arn arn:aws:iam::794929857501:policy/BackendDevPolicy --version-id v1
POLICYVERSION 2023-09-29T12:44:09+00:00      True    v1
DOCUMENT      2012-10-17
STATEMENT     Allow    *          VisualEditor0
ACTION        ec2:DescribeInstances
ACTION        secretsmanager:ListSecrets
STATEMENT     Allow    arn:aws:secretsmanager:us-east-1:794929857501:secret:prod/Customers-QUhpZf      VisualEditor1
ACTION        secretsmanager:GetSecretValue
ACTION        secretsmanager:DescribeSecret
```

Figure 12 BackendDevPolicy v1 actions and secret scope

```
C:\Users\miles>aws iam get-user-policy --user-name dev01 --policy-name S3_Access
S3_Access      dev01
POLICYDOCUMENT 2012-10-17
STATEMENT     Allow
ACTION        s3:ListBucket
ACTION        s3:GetObject
RESOURCE      arn:aws:s3:::hl-dev-artifacts
RESOURCE      arn:aws:s3:::hl-dev-artifacts/*
```

Figure 13 Inline S3_Access policy content

4. Identifying Accessible Resources (Data Exposure)

I validated S3 access. Global bucket listing was denied. Targeted listing and object reads were allowed.

S3 results

Global list result. AccessDenied for ListAllMyBuckets.

Bucket listing. hl-dev-artifacts shows three objects.
Download. flag.txt downloaded to the working directory.

Commands executed

aws s3 ls

aws s3 ls hl-dev-artifacts

aws s3 cp s3://hl-dev-artifacts/flag.txt .

```
C:\Users\miles>aws s3 ls
An error occurred (AccessDenied) when calling the ListBuckets operation: User: arn:aws:iam::794929857501:user/dev01 is not authorized to perform
: s3:ListAllMyBuckets because no identity-based policy allows the s3:ListAllMyBuckets action

C:\Users\miles>aws s3 ls hl-dev-artifacts
2023-10-01 16:39:53      1235 android-kotlin-extensions-tooling-232.9921.47.pom
2023-10-01 16:39:53    214036 android-project-system-gradle-models-232.9921.47-sources.jar
2023-10-01 16:38:05         32 flag.txt

C:\Users\miles>aws s3 cp s3://hl-dev-artifacts/flag.txt .
download: s3://hl-dev-artifacts/flag.txt to .\flag.txt

C:\Users\miles>
```

Figure 14 hl-dev-artifacts object listing & flag.txt downloaded from hl-dev-artifacts

5. Security Misconfigurations & Risks

Overbroad discovery on identities and policies. dev01 v7 grants many iam:Get* and iam:List* actions.

Direct S3 read. S3_Access grants ListBucket and GetObject on hl-dev-artifacts.

Role pivot risk. BackendDev trust names dev01 as principal. BackendDevPolicy includes Secrets read.

Secrets exposure path. If the role is assumed and KMS allows decrypt, prod/Customers-QUhpZf will be readable.

6. Flag Discovery & Documentation

Location

s3://hl-dev-artifacts/flag.txt

Commands

aws s3 ls hl-dev-artifacts

aws s3 cp s3://hl-dev-artifacts/flag.txt .

Flag value

d8ae4495888545df0c904551935c7514

7. Mitigation Strategies

S3 least privilege. Limit ListBucket and GetObject to exact prefixes. Remove bucket level list if not required.

Tighten role trust. Limit principals for BackendDev. Require MFA for assume role on sensitive roles.

Restrict secrets. Bind GetSecretValue to exact ARNs with tags. Enforce strict KMS key policies. Reduce identity discovery. Remove unneeded iam:Get* and iam:List* on roles and policies. Block escalation actions for non-admins. Deny iam:AttachUserPolicy, iam:CreatePolicyVersion, iam:SetDefaultPolicyVersion, iam:PassRole, and sts:AssumeRole to privileged roles. Enable and monitor S3 Block Public Access at the account level. Use IAM Access Analyzer to find unused or broad permissions and remove them.

8. Conclusion

User dev01 had effective S3 read to hl-dev-artifacts and retrieved the flag. The BackendDev trust and policy create a clear pivot to secrets. The controls reduce exposure and align access with least privilege. The lessons I learned in this assignment include some issues I ran into with the AWS CLI. At first, I compared the command line on my machine with the provided lab screenshots. I noticed that the formatting was off, which I believe is due to me specifying the “text” format when I was defining the “AWS Configure Default output format”. I should have made it “None” instead of “Text”. Another lesson that I learned was when I was trying to copy to flag.txt file from AWS S3 to my machine. I couldn’t find the flag file, and it took me a while to find the path, but it ended up being in a very specific place on my machine. For future assignments, I will keep track of where I will copy and move files from S3.